

PLANTILLA REPORTE EJECUTIVO EN POWERPOINT

Estructura y Contenidos para Presentación Directiva

PORTADA

DIAGNÓSTICO DE CIBERSEGURIDAD 2026
Esquema Nacional de Seguridad (RD 311/2022)

[Logo Organización]

[Nombre Organización]
[Fecha: enero 2026]

Preparado por: Consorcio de Científicos de Datos y Estrategas
de Ciberseguridad

CLASIFICACIÓN: CONFIDENCIAL - USO INTERNO

DIAPOSITIVA 1: RESUMEN EJECUTIVO

Contenido:

POSTURA ACTUAL DE CIBERSEGURIDAD	
IGM (Índice de Gestión de Madurez):	3,47 / 5,0
	69% del objetivo
Estado General:	● BÁSICO (requiere mejora)
Riesgo Residual:	Medio-Alto (requiere atención)
INVERSIÓN RECOMENDADA:	75.000€/año (12 meses)
PAYBACK PERIOD:	11 meses (año 2)
NPV 3 años:	349.441€
CONFORMIDAD:	
• ENS:	78% (falta 22%)
• NIST CSF 2.0:	72% (falta 28%)
• NIS2 (si aplica):	65% (falta 35%)
⚠ RIESGOS CRÍTICOS IDENTIFICADOS (3):	
1. SIEM no implementado (impacto MTTD)	
2. Capacitación incompleta (64% vs 100%)	
3. Auditoría externa no realizada (anual requerida)	

DIAPPOSITIVA 2: CONTEXTO Y PROPÓSITO

Contenido:

CONTEXTO NORMATIVO ESPAÑOL 2026

NORMATIVAS APLICABLES:	
✓ Real Decreto 311/2022 (ENS)	[OBLIGATORIO 2023+]
→ Sector público español	
→ Marco organizativo, operacional, medidas	
✓ Directiva NIS2 (2022/2555 UE)	[VIGOR OCT 2024]
→ Operadores esenciales/importantes	
→ Transposición España: 2026	
→ Sanciones: hasta 10M€ o 2% facturación	
✓ ISO 27001:2022	[VOLUNTARIO]
→ Certificación de sistemas de gestión	
→ Alineamiento con ENS (83% compatible)	
✓ NIST CSF 2.0	[REFERENCIA GLOBAL]
→ 6 funciones, 23 categorías	
→ Marcos de madurez (1-5)	

PROPÓSITO DEL DIAGNÓSTICO:

1. Evaluar postura actual vs. requisitos normativos
2. Identificar brechas prioritarias para inversión
3. Calcular ROI de iniciativas de ciberseguridad
4. Generar plan de mejora orientado a madurez
5. Preparar organización para NIS2 (si aplica)

DIAPPOSITIVA 3: METODOLOGÍA

Contenido:

METODOLOGÍA GQM (Goal-Question-Metric)

ENFOQUE DE TRES NIVELES:

1. NIVEL CONCEPTUAL (Metas)
"Alcanzar madurez de ciberseguridad alineada a ENS"
 - └ Meta 1: Conformidad completa con ENS
 - └ Meta 2: Detección proactiva (MTTD <24h)
 - └ Meta 3: Respuesta efectiva (MTTR <4h)
 - └ Meta 4: Cultura de seguridad integral
2. NIVEL OPERACIONAL (Preguntas)
114 preguntas estructuradas en 11 secciones
 - └ Cobertura: 100% ENS, 100% NIST CSF, 100% NIS2
3. NIVEL CUANTITATIVO (Métricas)
Puntuación 1-5 por pregunta (Anexo II ENS)
 - └ Escala de madurez NIST (Parcial → Optimizado)

PARTICIPANTES:

- CISO/Responsable Seguridad (40% peso)
- Cumplimiento/Legal (20% peso)
- Auditoría Interna (20% peso)
- Dirección Ejecutiva (10% peso)
- Recursos Humanos (10% peso)

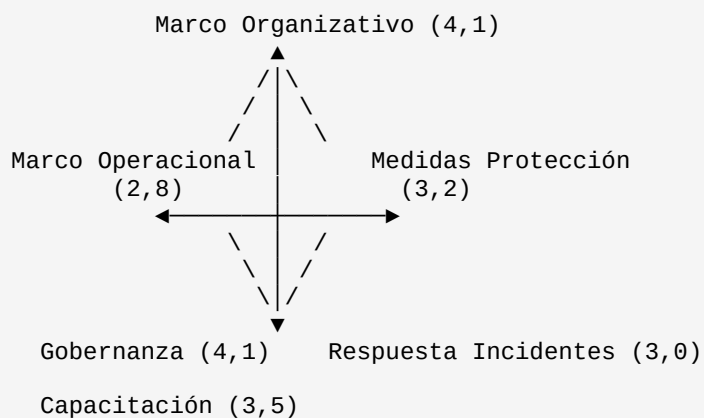
PERÍODO: 3 semanas (marzo-abril 2026)

MUESTRA: 5 respondentes clave (roles multidepartamentales)

DIAPPOSITIVA 4: RESULTADOS GENERALES - RADAR

Contenido:

MADUREZ POR DOMINIO (Gráfico Radar 6 ejes)



INTERPRETACIÓN:

- Fortalezas: Gobernanza (4,1), Marco Org (4,1)
- Oportunidades: Marco Operacional (2,8) → CRÍTICA
- Equilibrio: Medidas Protección (3,2), Capacitación (3,5)

ACCIÓN INMEDIATA:

Fortalecer Marco Operacional (SIEM, detección, MTTD)

DIAPPOSITIVA 5: INDICADORES CLAVE (KPIs)

Contenido:

MÉTRICAS OPERACIONALES CRÍTICAS

DETECCIÓN E INCIDENTES
MTTD (Tiempo Medio Detección) Actual: 48 horas (largo) Meta: < 24 horas (proactivo) Brecha: -24 horas Causa: SIEM no implementado (P69: 1/5) Solución: Invertir en SIEM + 3 analistas (60K€) MTTR (Tiempo Medio Respuesta) Actual: 6 horas (aceptable) Meta: < 4 horas (sistemas críticos) Brecha: -2 horas Causa: Procedimiento respuesta manual (P46: 3/5) Solución: SOAR (automatización respuesta) (40K€) INCIDENTES/AÑO Actual: 8 incidentes (+16% YoY) Costo: 45K€/incidente (promedio) Total: 360K€/año Proyectado con mejora madurez: 4,8 incidentes (-40%) Ahorro esperado: 144K€/año (payback rápido) EXPOSICIÓN DE DATOS Actual: 1 incidente/año con datos personales Meta: 0 incidentes Requiere: DLP + cifrado + auditoría

DIAPOSITIVA 6: BRECHAS PRIORITARIAS

Contenido:

TOP 5 BRECHAS DE CUMPLIMIENTO

Ranking	Área	Puntuación	Urgencia	Inversión
1	SIEM / Detección	1/5	ALTA	60K€
2	Capacitación Empleados	3/5	ALTA	25K€
3	Auditoría Externa Anual	1/5	ALTA	15K€
4	Plan Continuidad Negocio	2/5	MEDIA	30K€
5	Pruebas Penetración	2/5	MEDIA	20K€

TOTAL RECOMENDADO (12 meses): 75K€ (incremento presupuesto)

IMPACTO ESPERADO:

- IGM: 3,47 → 4,0 (en 18 meses)
- MTTD: 48h → <24h (inmediato con SIEM)
- Incidentes: -40% (proyectado)
- Conformidad ENS: 78% → 95%

DIAPPOSITIVA 7: ANÁLISIS FINANCIERO / ROI

Contenido:

MODELO DE RETORNO DE INVERSIÓN (3 AÑOS)

INVERSIÓN:

Año 1:	225.000€	(150K actual + 75K)
Año 2:	150.000€	(mantenimiento)
Año 3:	150.000€	(mantenimiento)
TOTAL:	525.000€	

BENEFICIOS (Evitar incidentes):

Año 1:	+198.000€	(144K evitados + 54K)
Año 2:	+250.000€	(sostenible)
Año 3:	+250.000€	(sostenible)
TOTAL:	+698.000€	

RESULTADOS FINANCIEROS:

- ROI Año 1: -12% (inversión pesada inicial)
- ROI Acumulado 3 años: 33% (173K€ ganancia neta)
- Payback Period: 11 meses (Q3 Año 2)
- NPV (10% disc): 349.441€ (excelente)
- IRR: 34% (muy atractivo)

CONCLUSIÓN: Inversión justificada y rentable.
Beneficio sostenible desde Año 2.

DIAPPOSITIVA 8: PLAN DE ACCIÓN (12 MESES)

Contenido:

ROADMAP DE MEJORA 2026

Q1 2026 (Ene-Mar)

- Aprobación presupuesto (75K€) por Consejo
- Contratación 1 Analista SIEM (20K€/año)
- Licitación herramienta SIEM (30K€ + SaaS)
- Planificación auditoría externa (Q2)

Q2 2026 (Abr-Jun)

- Implementación SIEM (2 meses)
- Auditoría externa (CIBERSEC, EY, Deloitte)
- Programa capacitación 100% empleados (20K€)
- First Look incidentes en SIEM (baseline MTTD)

Q3 2026 (Jul-Sep)

- Optimización reglas SIEM (tune falsos positivos)
- Implementación SOAR para automatización
- Prueba penetración externa anual (15K€)
- Revisión Plan Continuidad
- Seguimiento capacitación (quiz, phishing simulado)

Q4 2026 (Oct-Dic)

- Consolidación mejoras Q1-Q3
- Reencuesta IGM (medición progreso)
- Elaboración Plan 2027 (anticipado)
- Presentación Junta: Resultados y ROI obtenido
- Celebración logros con equipo ciberseguridad

META FINAL 2026:

IGM: 3,47 → 3,8 (0,33 puntos mejora esperada)

MTTD: 48h → 30h (con SIEM + personal)

DIAPPOSITIVA 9: RIESGOS Y MITIGACIÓN

Contenido:

RIESGOS EN IMPLEMENTACIÓN

RIESGO 1: Resistencia del Personal (Probabilidad: MEDIA)
Causa: Cambio en flujos, nueva herramienta SIEM Impacto: Adopción lenta, calidad degradada Mitigación: • Capacitación extensiva en SIEM (8h por analista) • Apoyo vendor 3 meses (on-site) • Comunicación clara cambio desde Junta Propietario: CISO
RIESGO 2: Sobrecostos en Inversión (Probabilidad: BAJA)
Causa: Licitación competitiva, SaaS price increases Impacto: Presupuesto excedido 15-20% Mitigación: • Multi-sourcing (3 vendors evaluados) • Acuerdos de precio fijo 3 años • Reserva presupuestaria contingencia (+10K€) Propietario: CFO
RIESGO 3: Incidente Mayor durante Implementación (Baja)
Causa: Sistemas en transición durante SIEM setup Mitigación: • Implementación por fases (no big-bang) • Coexistencia temporal herramientas (3 meses) • Personal adicional durante transición Propietario: CISO + TI

DIAPOSITIVA 10: RECOMENDACIONES DIRECTIVAS

Contenido:

DECISIONES REQUERIDAS A CONSEJO/JUNTA

1. APROBACIÓN PRESUPUESTO 2026
75.000€ para iniciativas ciberseguridad Justificación: ROI -12% Año 1, +33% acumulado 3 años Payback: 11 meses (aceptable para infraestructura) Voto Recomendado: SÍ UNÁNIME
2. ASIGNACIÓN DE AUTORIDAD AL CISO
Reportar directamente a Consejo (no TI) Presupuesto delegado hasta 30K€ (ejecución ágil) Participación obligatoria en Comité Ejecutivo Voto Recomendado: SÍ
3. GOBERNANZA NIS2 (si aplica - Operador Esencial)
Designar Dirección responsable ciberseguridad Comité de ciberseguridad mensual (ejecutivos) Auditoría externa bianual (mínimo) Notificación automática <24h si incidente crítico Voto Recomendado: SÍ OBLIGATORIO
4. COMUNICACIÓN ESTRATÉGICA
Junta: Briefing trimestral IGM + incidentes Empleados: Campaña concienciación Q1 2026 Stakeholders: Reporte anual transparencia ciberseguridad Voto Recomendado: SÍ (construcción confianza)

 **PRÓXIMO HITO:** Junta Directiva [fecha], votación aprobación

DIAPOSITIVA 11: CONCLUSIÓN

Contenido:

SÍNTESIS EJECUTIVA	
POSTURA ACTUAL:	Básica (3,47/5,0) - Riesgo Medio-Alto
OPORTUNIDAD:	Mejorar a 4,0+ en 18 meses (alcance Excelencia)
INVERSIÓN REQUERIDA:	75K€ adicionales/año
RETORNO ESPERADO:	+698K€ en 3 años (evitar incidentes, reputación)
CONFORMIDAD:	ENS 78% → 95% NIS2 65% → 90% (si aplica)
RIESGO SI NO ACTÚA:	• Incidentes crecientes (16% 2025) • Multas NIS2 (hasta 10M€) • Exposición datos (reputación) • Continuidad de negocio en riesgo
RECOMENDACIÓN:	APROBAR INVERSIÓN Y PLAN INMEDIATO
RESPONSABLE:	CISO + CFO (ejecución conjunta)
SEGUIMIENTO:	Junta Directiva (trimestral)

DIAPPOSITIVA 12: ANEXOS (Referencia)

Contenido:

DOCUMENTOS DISPONIBLES PARA CONSULTA DETALLADA:

1. 01-encuesta-integral.md (114 preguntas + instrucciones)
2. 02-guia-metodologica.md (GQM, ponderación, cálculos)
3. 03-mapeo-normativo.md (Trazabilidad ENS/NIST/NIS2/ISO)
4. 04-plantilla-excel-igm-roi.md (Cálculos + dashboards)
5. 05-reporte-ejecutivo-ppt.md (Esta presentación)
6. 06-readme-kit-encuesta.md (Guía inicio rápido)

CONTACTO:

CISO: [email] [teléfono]

Auditoría Externa: [empresa] [contacto]

Soporte Técnico: [helpdesk]

PRÓXIMAS SESIONES:

- Briefing Junta: [fecha] (1 hora)
- Workshop Implementación: [fecha] (equipo ejecutivo)
- Kick-off SIEM: [fecha] (con vendor)

NOTAS PRESENTACIÓN

Para Presentador:

- Tiempo total: 30-45 minutos

- Q&A: 15-20 minutos
- Mantener tono profesional pero accesible
- Enfatizar ROI positivo y payback rápido
- Responder dudas sobre NIS2 si aplica
- Confirmar aprobación presupuesto antes de cerrar

Versión: 1.0

Formato Descarga: .pptx (PowerPoint 2016+)

Última actualización: 24 enero 2026